SAI SentinelAI FYP2 • Landscape Architectural Poster

Print / Save Landscape PDF

SENTINELAI • FINAL YEAR PROJECT 2 Core Finding Architecture Comparison

# Full Report (No. 6) VS Simplified Report (No. 2)

FULL REPORT (NO. 6)
**9 Heavy Technical Fields**

SIMPLIFIED REPORT (NO. 2)
**Only 3 Things (Symptom · Risk · Fix)**

## 6 Detailed Technical Finding Dossier

Audience: Security Engineers, Pentesters, Auditors

9 Heavy Fields

[1. ID] SEC-FIND-042

### SQL Injection in Search Query Parameter

[2. CVSS] 9.4 CRITICAL

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

[3. & 4. TAXONOMIES]
CWE-89 · OWASP A03:2021-Injection

[5. TARGET LOCATION]
/api/v1/search?q= (db.js:142)

[6. TECHNICAL MECHANISM & DESCRIPTION]
Unsanitized query string concatenated into dynamic PostgreSQL statement, allowing SQL subquery execution and table exfiltration.

[7. EXPLOITATION POC & ATTACK PAYLOAD]

```
curl -i -s -k -X $'GET' 'https://target.com/search?q=\'%20UNION%20SELECT%20null,username,password_hash%20FROM%20users--'
```

[8. RAW HTTP EVIDENCE & SCANNER LOG]

```
HTTP/1.1 200 OK
Content-Type: application/json
[{"username":"admin","password_hash":"$2b$12$e8YxPqZ..."}]
```

**[9. Deep Remediation]:** Use parameterized prepared statements (`$1`). Ref: CVE-2023-34034

Focus: **Exhaustive Exploit Proof & Forensic Verification** Auditor & CISO Ready

## 2 "Your Fix Cards" (Actionable Playbook)

Audience: Sysadmins, IT Admins, Webmasters, Ops

ONLY 3 THINGS

ACTION ITEM #1

### Database Query Input Concatenation Flaw

FIX TODAY | MODERATE | ~30 MIN

**THING 1: SYMPTOM (WHAT WAS FOUND)**
User search queries are directly inserted into database commands without input validation.

**THING 2: RISK (WHY IT MATTERS)**
Attackers can bypass login screens, steal customer databases, or modify confidential stored records.

**THING 3: PRESCRIPTION (HOW TO FIX)**

```
Replace raw query with parameterized prepared statement: db.query("SELECT * FROM items WHERE name = $1", [userInput])
```

✓ **Verification:** Run test query with single-quote `'` and confirm HTTP 200 without SQL error.

Focus: **Fast Mean Time to Remediate (MTTR) • Zero Jargon** Medical Analogy Standard

**CONTEXT IN WHOLE DOCUMENT:** **Full Report:** No. 6 is 1 of 7 Chapters (Cover, TOC, Exec Summary, Methodology, OWASP, **No. 6 Findings**, Appendix)

**Simplified Report:** No. 2 is 1 of 3 Stages (1. SLA Posture, **No. 2 Fix Cards**, 3. Sign-Off)